

# Threat Analysis Report

รายงานวิเคราะห์ ปฏิบัติการจารกรรมทางไซเบอร์  
ของแฮกเกอร์ Jewelbug

27/08/2026

TLP:CLEAR



## สารบัญ

หน้า

|                                                          |    |
|----------------------------------------------------------|----|
| บทสรุปสำหรับผู้บริหาร.....                               | 3  |
| Threat Actor Profiles .....                              | 4  |
| การวิเคราะห์เชิงเทคนิค.....                              | 7  |
| Tactics, Techniques, and Procedures (MITRE ATT&CK) ..... | 9  |
| Indicators of Compromise (IoCs) .....                    | 10 |
| แนวทางการเฝ้าระวัง ป้องกัน และรับมือ .....               | 13 |
| อ้างอิง (References).....                                | 15 |

## บทสรุปสำหรับผู้บริหาร

รายงานฉบับนี้เป็นการวิเคราะห์เชิงลึกเกี่ยวกับปฏิบัติการภัยคุกคามทางไซเบอร์ของกลุ่มแฮกเกอร์ประเทศจีนที่มีชื่อว่า "Jewelbug" (หรือรู้จักในชื่อ Ink Dragon, Earth Alux, REF7707, CL-STA-0049) ซึ่งเริ่มตรวจพบแคมเปญระลอกใหญ่ตั้งแต่ต้นปี 2025 จนถึงปัจจุบัน โดยมีรูปแบบการปฏิบัติการแบบคู่ขนาน (Dual Missions) ผสานการจารกรรมข้อมูลเชิงกลยุทธ์ (Cyber Espionage) เข้ากับการก่ออาชญากรรมหลอกลวงคริปโตเคอร์เรนซี (Large-scale Cryptocurrency Fraud)

กลุ่มผู้โจมตีใช้แพลตฟอร์มศูนย์กลางชื่อ XG-Web ในการสร้างมัลแวร์ ควบคุมเครื่องเหยื่อ และรวบรวมข้อมูล โดยมีเป้าหมายครอบคลุมทั้งหน่วยงานภาครัฐ กองทัพ ตำรวจ หน่วยงานข่าวกรอง บริษัทอุตสาหกรรมและการบินขนาดใหญ่ในสหรัฐฯ ตลอดจนผู้ใช้งานคริปโตเคอร์เรนซีทั่วไป มีประวัติการใช้มัลแวร์ 4 ชนิดหลัก ได้แก่ VARGEIT, Antino, ClientKing, และ PDF Viewer พร้อมทั้งใช้โดเมน [www.ljkskhei.com](http://www.ljkskhei.com) เป็นโครงสร้างพื้นฐาน Command-and-Control (C2) ส่งผลให้มีการขโมยเซสชันคุกกี้มากกว่า 580,000 ชุด รหัสผ่านหลายพันชุด และอีเมลราชการกว่า 2,300 ฉบับ องค์การจึงควรยกระดับการเฝ้าระวังและป้องกัน

## Threat Actor Profiles

กลุ่ม Jewelbug (หรือที่รู้จักในวงการความมั่นคงปลอดภัยไซเบอร์ภายใต้ชื่อเรียกอื่นๆ ได้แก่ Ink Dragon, Earth Alux, REF7707 และ CL-STA-0049) เป็นกลุ่มแฮกเกอร์รับจ้าง ที่มีฐานปฏิบัติการอยู่ในประเทศจีน กลุ่มนี้เริ่มปรากฏความเคลื่อนไหวอย่างชัดเจนตั้งแต่ช่วงต้นเดือนพฤษภาคม ปี 2025 จนถึงปัจจุบัน แม้ว่ารูปแบบการโจมตีและการเลือกเป้าหมายจะสอดคล้องกับผลประโยชน์ของรัฐบาลจีน แต่จากหลักฐานด้านเอกสารยืนยันตัวตนของผู้ปฏิบัติการและข้อมูลการจดทะเบียนนิติบุคคล พบว่ากลุ่มนี้มีความเชื่อมโยงกับบริษัทที่จดทะเบียนอย่างถูกต้องในมณฑลหูหนาน (Hunan) ซึ่งบ่งชี้ว่าพวกเขาดำเนินงานในลักษณะองค์กรเชิงพาณิชย์ที่รับจ้างโจมตีทางไซเบอร์ มากกว่าจะเป็นหน่วยงานของรัฐโดยตรง

ความโดดเด่นของ Jewelbug คือการดำเนิน "ปฏิบัติการแบบคู่ขนาน" (Dual Missions) โดยใช้โครงสร้างพื้นฐาน ทีมงาน และระบบควบคุมเดียวกันในการทำภารกิจ 2 รูปแบบพร้อมกัน ได้แก่ การจารกรรมข้อมูลเชิงกลยุทธ์ (Strategic Cyber Espionage) และการก่ออาชญากรรมทางคริปโตเคอร์เรนซี (Large-scale Cryptocurrency Fraud) เพื่อมุ่งหวังผลกำไรทางการเงิน

กลุ่มเป้าหมายและขอบเขตการโจมตี (Target Scope & Victims) ปฏิบัติการจารกรรมข้อมูลของกลุ่มนี้มุ่งเป้าไปที่หน่วยงานระดับสูงที่มีความอ่อนไหวทางความมั่นคง ครอบคลุมทั้งหน่วยงานภาครัฐ กองทัพ กองทัพเรือ สำนักงานตำรวจ และหน่วยงานข่าวกรอง โดยเฉพาะในภูมิภาคเอเชียใต้ เอเชียตะวันออกเฉียงใต้ และตะวันออกกลาง ในภูมิภาคตะวันออกกลาง กลุ่มนี้ประสบความสำเร็จในการเจาะระบบผู้ให้บริการ Web Hosting ของรัฐบาล และฝังโค้ดอันตรายลงในระบบ Webmail ส่วนกลางที่ใช้งานร่วมกันในหลายกระทรวง นอกจากนี้ในภูมิภาคเอเชียใต้ ยังพบเป้าหมายที่เป็นบัญชีอีเมลของตำรวจและรัฐบาลถูกโจมตีกว่า 90 บัญชี

นอกเหนือจากหน่วยงานรัฐแล้ว Jewelbug ยังพุ่งเป้าไปที่ภาคเอกชนขนาดใหญ่ เช่น บริษัทผู้ผลิตในภาคอุตสาหกรรมและอากาศยาน (Industrial and Aerospace) รายใหญ่ของสหรัฐอเมริกา ในขณะเดียวกัน ภารกิจด้านอาชญากรรมทางการเงินของกลุ่มนี้ ได้พุ่งเป้าไปที่กลุ่มผู้ใช้งานคริปโตเคอร์เรนซีทั่วไป โดยการสร้างเว็บไซต์หลอกลวงที่สร้างขึ้นด้วย AI (เช่น เว็บไซต์เทรดคริปโตหรือเว็บพนันปลอม) และใช้เทคนิค SEO Poisoning ร่วมกับบอท (Click-fraud) เพื่อปั่นอันดับบน Search Engine ให้เหยื่อหลงเชื่อ

## ระบบนิเวศเครื่องมือและโครงสร้างพื้นฐาน (Tooling Ecosystem & Infrastructure)

ความสำเร็จของ Jewelbug เกิดจากการพัฒนาระบบนิเวศมัลแวร์ (Custom Toolset) แบบบูรณาการ ซึ่งถูกบริหารจัดการผ่านศูนย์กลางบนแพลตฟอร์มแบบ SaaS ที่ชื่อว่า "XG-Web" (พัฒนาด้วย React, Node.js และ MySQL) แพลตฟอร์มนี้มีระบบจัดการสิทธิ์การเข้าถึงของผู้ปฏิบัติการ (Role-Based Access Control) เพื่อควบคุมการแพร่กระจายมัลแวร์และรวบรวมข้อมูลเหยื่อทั้งหมด โดยมีเครื่องมือหลัก 4 ชนิด ได้แก่

1. VARGEIT (Squidoo / FinalDraft): มัลแวร์ประเภท Backdoor ที่ใช้เจาะระบบเซิร์ฟเวอร์ Microsoft IIS และ SharePoint ที่มีช่องโหว่ มีความสามารถสูงในการสร้างช่องทาง C2 ลับ (Covert Channels) ผ่านบริการที่ถูกกฎหมาย เช่น Microsoft Graph หรือ Outlook API รวมถึงการใช้เทคนิค DNS Tunneling และ ICMP Tunneling เพื่อหลบเลี่ยงการตรวจจับ
2. Antino: มัลแวร์ประเภท Windows Backdoor และ Infostealer ที่มักถูกแพร่กระจายผ่านหน้าต่างแจ้งเตือนให้อัปเดต Adobe Flash ปลอม ทำหน้าที่ในการดักจับรหัสผ่าน ข้อมูลระบบ และบันทึกภาพหน้าจอ
3. ClientKing: มัลแวร์ประเภท Linux Infostealer ที่พัฒนาด้วยภาษา Rust ใช้สำหรับการบุกรุกเครื่องแม่ข่าย Linux และอุปกรณ์เครือข่าย (Router) รองรับการเปิด Interactive Shell และทำ SOCKS Pivoting เพื่อเข้าถึงระบบเครือข่ายภายใน
4. PDF Viewer: ส่วนขยายเบราว์เซอร์อันตราย (Malicious Extension) ที่แฝงตัวมาเพื่อขโมย Cookies, Session Tokens และประวัติการท่องเว็บ มัลแวร์ตัวนี้สามารถข้าม Sandbox ของเบราว์เซอร์ผ่าน Windows Native Messaging (com.microsoft.runedge) และยังมีฟังก์ชัน "Clipper" สำหรับสลับที่อยู่กระเป๋าเงินคริปโตของเหยื่อขณะทำธุรกรรมแบบเรียลไทม์

ระบบเครื่องมือทั้งหมดนี้ ทำให้กลุ่ม Jewelbug สามารถปฏิบัติการในอัตราความเร็วที่สูงมาก (High-tempo phase) โดยพบว่าในช่วงเวลาไม่ถึง 3 เดือน แพลตฟอร์มของพวกเขามีการบันทึกการเชื่อมต่อกลับ (Check-ins) มากกว่า 1 ล้านครั้ง ขโมยคุกกี้เบราว์เซอร์ไปกว่า 580,000 ชุด และดึงข้อมูลอีเมลราชการสำคัญออกไปได้มากกว่า 2,300 ฉบับ

| TA Name & Aliases                                          | Tools & Frameworks                                                                                                                                                                                                                                                                           | Target Scope & Victims                                                                                                                                                       |
|------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Jewelbug<br>(Ink Dragon, Earth Alux, REF7707, CL-STA-0049) | <ul style="list-style-type: none"> <li>- XG-Web (C2 Management Platform)</li> <li>- VARGEIT (IIS/SharePoint Backdoor)</li> <li>- Antino (Windows Backdoor/Spyware)</li> <li>- ClientKing (Linux/Router Implant)</li> <li>- PDF Viewer (Malicious Browser Extension &amp; Clipper)</li> </ul> | <ul style="list-style-type: none"> <li>- หน่วยงานภาครัฐ กองทัพ ตำรวจ ข้าราชการ (เอเชียใต้, ตะวันออกกลาง)</li> <li>- ผู้ใช้งานแพลตฟอร์มคริปโตเคอร์เรนซีและเว็บพนัน</li> </ul> |



## การวิเคราะห์เชิงเทคนิค

### Attack Flow

#### 1. Initial Access & Staging (การเข้าถึงและเตรียมการ)

- **เจาะช่องโหว่ IIS/SharePoint และฝัง VARGEIT:** ผู้โจมตีอาศัยช่องโหว่บนระบบ Microsoft IIS และ SharePoint เพื่อเข้าถึงเครื่องแม่ข่ายและติดตั้งมัลแวร์ Backdoor ชื่อ VARGEIT
- **Watering-Hole บน Webmail:** ฝังโค้ด JavaScript อันตรายลงในหน้าล็อกอินของระบบ Webmail ภาครัฐ เพื่อดักจับข้อมูลการเข้าสู่ระบบและขโมยเซสชันคุกกี้
- **SEO Poisoning & เว็บริปโตปลอมจาก AI:** สร้างเว็บไซต์หลอกลวง (Phishing) และเว็บพนันปลอมด้วย AI พร้อมใช้เทคนิค Click-fraud และปั่นอันดับบน Search Engine เพื่อลวงให้เหยื่อเข้าถึงและดาวน์โหลดมัลแวร์
- **ซ่อน Payload บน Google Docs / HTA:** ฝากไฟล์ Payload ไว้บนบริการคลาวด์สาธารณะ (Google Docs) และใช้สคริปต์ HTA ในการดาวน์โหลดโค้ดอันตรายลงสู่เครื่องเหยื่อ

#### 2. Payload Delivery & Execution (การส่งมอบและรันคำสั่ง)

- **ลวงอัปเดต Adobe Flash ปลอมและติดตั้งมัลแวร์:** แสดงหน้าต่างแจ้งเตือนให้อัปเดต Adobe Flash ปลอม เพื่อส่งมอบและติดตั้งมัลแวร์ 3 ชนิดหลัก ได้แก่ Antino (Windows), ClientKing (Linux/Network Devices) และส่วนขยายอันตราย PDF Viewer (Web Browser)

#### 3. Privilege Escalation & Evasion (การยกระดับสิทธิ์และหลบเลี่ยง)

- **หลบเลี่ยง Sandbox ผ่าน Native Messaging:** ส่วนขยายเบราว์เซอร์ PDF Viewer ข้ามการควบคุมของ Sandbox ผ่านกลไก Windows Native Messaging (com.microsoft.runedge) เพื่อสั่งการและรันโค้ดระดับไฮสแต

#### 4. Collection & Credential Access (การรวบรวมข้อมูลและขโมยสิทธิ์)

- **รวบรวมข้อมูลและขโมยข้อมูลระบุตัวตน:** ดักจับข้อมูลสถานะระบบ บันทึกภาพหน้าจอจรหัสผ่านที่บันทึกไว้ในระบบ และเซสชันคุกกี้เพื่อส่งกลับไปยังเซิร์ฟเวอร์ควบคุม
- **ส่งข้อมูลผ่าน WebSocket และสลับที่อยู่กระเป๋าเงิน (Clipper):** ส่งข้อมูลคุกกี้ผ่านโพรโทคอล WebSocket แบบเรียลไทม์ และแอบสลับที่อยู่กระเป๋าเงินคริปโตเคอร์เรนซีของเหยื่อขณะทำธุรกรรม

## 5. Command and Control (C2) / Exfiltration (การควบคุมและส่งข้อมูลออก)

- สื่อสารผ่านช่องทางลับและควบคุมผ่าน XG-Web: ใช้เทคนิค DNS Tunneling, ICMP Tunneling และ Microsoft Graph / Outlook API เป็นช่องทาง C2 สำหรับการสื่อสารและส่งข้อมูลกลับไปยังโดเมน [www\[.\]jkskhei\[.\]com](http://www[.]jkskhei[.]com) ซึ่งเชื่อมโยงกับแพลตฟอร์มบริหารจัดการศูนย์กลาง XG-Web



ภาพ Attack Flow



## Tactics, Techniques, and Procedures (MITRE ATT&CK)

MITRE ATT&CK คือฐานความรู้ที่รวบรวมและจัดหมวดหมู่กลยุทธ์และเทคนิคต่างๆ ที่ผู้ไม่หวังดีใช้ในการโจมตีทางไซเบอร์ โดยอ้างอิงจากเหตุการณ์ที่เกิดขึ้นจริง เพื่อให้ฝ่ายป้องกันสามารถเข้าใจและรับมือกับภัยคุกคามได้ดียิ่งขึ้น

| Tactic            | Technique ID | Technique Name                                                        |
|-------------------|--------------|-----------------------------------------------------------------------|
| Initial Access    | T1190        | Exploit Public-Facing Application                                     |
|                   | T1189        | Drive-by Compromise                                                   |
| Execution         | T1059.005    | Command and Scripting Interpreter: Visual Basic                       |
|                   | T1204.002    | User Execution: Malicious File                                        |
| Persistence       | T1176        | Browser Extensions                                                    |
|                   | T1546        | Event Triggered Execution                                             |
| Defense Evasion   | T1176        | Browser Extensions (Sandbox Escape via Native Messaging)              |
|                   | T1027        | Obfuscated Files or Information                                       |
| Credential Access | T1539        | Steal Web Session Cookie                                              |
|                   | T1555        | Credentials from Password Stores                                      |
| Collection        | T1115        | Clipboard Data (Clipper Mechanism)                                    |
|                   | T1125        | Video Capture / Screen Capture                                        |
| Command & Control | T1071.001    | Application Layer Protocol: Web Protocols                             |
|                   | T1071.004    | Application Layer Protocol: DNS                                       |
|                   | T1572        | Protocol Tunneling (DNS & ICMP Tunneling)                             |
|                   | T1095        | Non-Application Layer Protocol (ICMP)                                 |
| Impact            | T1102        | Web Service (Microsoft Graph / Outlook API)                           |
|                   | T1565.001    | Data Manipulation: Stored Data Manipulation (Wallet Address Swapping) |

## Indicators of Compromise (IoCs)

Indicators of Compromise (IoCs) คือ ร่องรอยหรือหลักฐานทางดิจิทัลที่บ่งชี้ว่าระบบหรือเครือข่ายอาจถูกบุกรุกโดยผู้ไม่หวังดี ซึ่งทาง สกมช. ได้มีการแบ่งปันข้อมูล IOCs เหล่านี้ผ่านทางแพลตฟอร์ม MISP (Malware Information Sharing Platform) เพื่อเสริมสร้างความมั่นคงปลอดภัยไซเบอร์เรียบร้อยแล้ว โดยมีร่องรอยที่สามารถตรวจสอบได้ดังนี้

### Domain

microsoft-flash[.]com

dns[.]wizkidblogger[.]com

ns1[.]jkskhei[.]com

www[.]jkskhei[.]com

www[.]f1ash[.]org[.]cn

www[.]wps-cn[.]com

robot[.]javbliud[.]com

fonts[.]chrone[.]com

fonts[.]tarotfree101[.]top

### IPv4 Address

219.76.254[.]184

47.250.208[.]35

47.87.71[.]167

129.212.237[.]224

38.12.1[.]47

167.71.195[.]255

47.84.51[.]173

47.84.37[.]113

43.246.208[.]179

43.246.208[.]236

152.42.174[.]151

103.87.9[.]62

SHA-256

ed96e7f1085a50251eb8967ac53777272a617831084f0edad8a769c583a18869  
ea893abf20b00d9bfc042a88bf7b4bd42e68ce07c116d3e3b002e5b4a853877  
e782a6d4919f194d41e524ebd6df5894197043cf772fcf60455127b246f302c0  
ac3d453d3c9b0310ebb8a67cef35e2ac954d4acdf70cf497fe43a02c7a510813  
97c3a6be1711c5340d8806e4a54f7297f3f763d0aa4240b667f1e4e1f98f2aad  
6d5fe6b6a34eeb470798b970b70f41a07ccf59b22f49ad9b3dfff7aa3256f3c2  
5edb8d1023b8babf302871b68fa2b26d5ca57633f64951922998e8f1d6c8f7ac  
5ccdf53881f6c758af8d94fe67066af209b4bc0a3cb80b6a4c724fad86eb97ef  
430f12970f8d58f12edccee9019a1aa90fa232c961449bdcc69c8d348a52cf55  
30f5122cc199b9c2e524503b343a9ee13a6f9773dcbc1df82c8b25ad20bca61d  
297413a3e49e7353bf484a3eb15ec647de729211059df8fc68678d2378b6f561  
153d077bcb58e00f5746573cba25f6b0788b809bf7b2a52fca0dc22d3bb5c94e  
9b7df409c9a89f7536d3ba7b6d43fb6dbac618c8bb52615ba34cc971ad71bbf3  
0c39264337a1186b2e765e24073399cbdcba118306614eb411e315887af578bd  
b90a4e770869c28fd2140acb3ebdc50c113bb6f096b4bbdb9ac87c349c70e85e  
c11714f9fe2df1ca906585c81498cd77f5ec05b132aab73fa3a71d71d71e42cc  
09ef7c736bccfafefc44d9910d499173b88063b73b221fc0dc9e9105107e5cff  
e7e3b0bcd6798634adf8b49d305f3a7b7682e4b76db549682a183c5a186df4bb  
e2eb7703047b37b28dc34e6990205d758a2454b39bc655b460606745fadcb530  
f1ef5fe4c0cdcff13cc750c867728b89719f81437bdc49041edd1ae1f3edb4e8  
e809da86bd81463347fa7f922d3e088755a94a331889d32acb55aa8f57778a34  
01b5c6acb20e41799a0e96d9d1d6e1c44791883706b6285e874fcb15cc93b31a  
e6ff096a0562c0042b09d250bd60272ffcd8d72bd95c563842acf765a8dc8bcf

#### URL

hxxps://fonts[.]chrome[.]com/dist/js/12.qgfvjzvs[.]chunk.js

hxxps://www[.]lf1ash[.]org[.]cn/flashcenter\_pp\_ax\_install\_cn.exe

hxxps://microsoft-flash[.]com/download/Adobeinstall.exe

hxxps://microsoft-flash[.]com/download/flashcenter\_pp\_ax\_install\_en.exe

## แนวทางการเฝ้าระวัง ป้องกัน และรับมือ

### 1. การเฝ้าระวังเชิงรุก (Proactive Monitoring & Detection)

- การตรวจจับความผิดปกติระดับเครือข่าย (Network Traffic Analysis):
- DNS Tunneling: เฝ้าระวังและวิเคราะห์ปริมาณคำขอ DNS Queries ที่มีขนาด Subdomain ยาวผิดปกติ หรือมีความถี่สูงไปยังเนมเซิร์ฟเวอร์ภายนอก เพื่อตรวจจับช่องทางสื่อสาร C2 ของ VARGEIT และ ClientKing
- ICMP Tunneling: ตรวจสอบแพ็กเก็ต ICMP Echo Request/Reply ที่มีขนาด Payload ใหญ่กว่าค่ามาตรฐาน หรือมีการส่งต่อเนื่องเป็นระยะเวลานาน
- Webmail & WebSocket Traffic: ตรวจจับการเชื่อมต่อ WebSocket ภายนอกจากเบราว์เซอร์ของผู้ใช้งานขณะเปิดหน้าล็อกอินหรือกล่องข้อความของระบบ Webmail องค์กร เพื่อป้องกันการขโมยคุกกี้แบบเรียลไทม์
- **C2 Infrastructure:** เฝ้าระวังการสืบค้นชื่อโดเมน (DNS Lookup) หรือการเชื่อมต่อขาออกไปยัง `www[.]jkskhei[.]com` และ IP ปลายทางที่เกี่ยวข้องในระดับ Firewall และ Proxy
- การตรวจจับระดับระบบแม่ข่ายและเครื่องลูกข่าย (Endpoint & Host-Level Detection):
- Native Messaging Interface: ตรวจสอบการลงทะเบียนของ Registry Key ในพาท `HKCU\Software\Google\Chrome\NativeMessagingHosts` หรือ `HKLM\Software\Microsoft\Edge\NativeMessagingHosts` โดยเฉพาะค่าที่อ้างอิงถึง `com.microsoft.runedge`
- Web Server Anomalies (IIS / SharePoint): ตรวจจับการสร้างโปรเซสลูกที่ผิดปกติจาก `w3wp.exe` (เช่น `cmd.exe`, `powershell.exe`) และมอนิเตอร์การแก้ไขไฟล์ Script บนเซิร์ฟเวอร์
- Script & Utility Execution: เฝ้าระวังการเรียกใช้งาน `mshta.exe`, `cscript.exe`, หรือ `wscript.exe` ที่มี Command-line arguments อ้างอิงถึง URL ภายนอกหรือบริการคลาวด์สาธารณะ (Google Docs)
- Linux & Network Devices: ตรวจสอบโปรเซสที่ทำงานเบื้องหลังบนเซิร์ฟเวอร์ Linux และอุปกรณ์ Router เพื่อค้นหาไฟล์ไบนารีภาษา Rust ที่ไม่ทราบแหล่งที่มา รวมถึงตรวจจับการเปิดใช้งานพอร์ต SOCKS Proxy
- การเฝ้าระวังด้านตัวตนและบัญชีผู้ใช้งาน (Identity & Cloud Monitoring) Session Token Anomalies: ตรวจจับการใช้งาน Session Cookie ที่มีการล็อกอินพร้อมกันจากต่างพื้นที่ (Impossible Travel) หรือเชื่อมต่อมาจาก IP/ASN ของโฮสต์ตั้งและ VPN ที่ผิดปกติ
- API Activity Auditing: ตรวจสอบบันทึกการใช้งาน Microsoft Graph API และ Outlook API ที่มีการร้องขอเข้าถึงกล่องจดหมาย หรือการส่งข้อมูลออกโดยไม่มีประวัติการยืนยันตัวตนแบบปกติ

## 2. มาตรการป้องกันเชิงโครงสร้าง (Preventative Hardening)

- การจัดการช่องโหว่: เร่งติดตั้งแพตช์ความปลอดภัยล่าสุดของ Microsoft IIS, Microsoft SharePoint และระบบแม่ข่ายที่ให้บริการสื่อบริการอินเทอร์เน็ตทันที พร้อมติดตั้ง Web Application Firewall (WAF) เพื่อป้องกันการฝังโค้ดบน Webmail
- การควบคุมเบราว์เซอร์: บังคับใช้นโยบายกลุ่ม (Group Policy / MDM) ในการควบคุม Browser Extension โดยใช้ระบบ Whitelist อนุญาตเฉพาะส่วนขยายที่ผ่านการรับรอง และบล็อกส่วนขยายชื่อ 'PDF Viewer' ที่ไม่ได้มาจากแหล่งเผยแพร่ทางการ
- การควบคุมสคริปต์: กำหนดกฎ Attack Surface Reduction (ASR) หรือ AppLocker เพื่อระงับการทำงานของไฟล์ .hta, VBScript และ Scripting Engine ที่ไม่จำเป็น รวมถึงจำกัดสิทธิ์ของ Service Account ตามหลัก Least Privilege
- การสกัดกั้นเครือข่าย: เพิ่มโดเมน www[.]jkskhei[.]com ลงใน DNS Sinkhole, Secure Web Gateway (SWG) และ Firewall Blacklist พร้อมทั้งจำกัดการเชื่อมต่อขาออก (Outbound Egress Filtering) ของเครื่องแม่ข่าย

## 3. การรับมือและแก้ไขเหตุการณ์ (Incident Response & Remediation)

- ขั้นตอนที่ 1: การตัดการเชื่อมต่อและกักกัน (Isolation & Containment): ตัดการเชื่อมต่อเครือข่ายทันที (Network Isolation) สำหรับเครื่องแม่ข่ายและลูกข่ายที่ตรวจพบมัลแวร์ (VARGEIT, Antino, ClientKing) รวมถึงตรวจสอบอุปกรณ์ Router ที่อาจถูกแทรกแซง และบล็อกการสื่อสาร DNS/ICMP/WebProtocols ที่เชื่อมต่อไปยังโครงสร้าง C2
- ขั้นตอนที่ 2: การจัดการสิทธิ์และตัวตน (Identity Invalidation): เพิกถอน Active Sessions (Revoke Refresh Tokens & Cookies) ของบัญชีที่ต้องสงสัยทั้งหมดในระบบ Webmail, Cloud Identity (Azure AD/Entra ID) และบังคับเปลี่ยนรหัสผ่านใหม่พร้อมลงทะเบียน MFA ซ้ำ
- ขั้นตอนที่ 3: การกวาดล้างและทำความสะอาดระบบ (Eradication & System Cleaning): ลบส่วนขยายเบราว์เซอร์ปลอมและลบ Registry Key ที่เกี่ยวข้องกับ Native Messaging (com.microsoft.runeledge) รวมถึงตรวจสอบโค้ดระบบ Webmail/SharePoint เพื่อลบสคริปต์แปลกปลอม และทำการ Full Scan ด้วย EDR
- ขั้นตอนที่ 4: การฟื้นฟูและการแลกเปลี่ยนข้อมูล (Recovery & Verification): ตรวจสอบประวัติการทำธุรกรรมคริปโตเคอร์เรนซีเพื่อระบุการถูกสลับกระเป๋าเงินจาก Clipper และนำข้อมูล IoCs/TTPs ส่งต่อเข้าสู่แพลตฟอร์ม MISP เพื่อยกระดับการเฝ้าระวังในภาคีเครือข่าย

## อ้างอิง (References)

1. <https://thehackernews.com/2026/08/china-linked-jewelbug-uses-xg-web-for.html>
2. <https://www.infosecurity-magazine.com/news/researchers-link-chinese-apt-hack/>
3. <https://www.security.com/threat-intelligence/jewelbug-apt-russia>
4. <https://www.security.com/threat-intelligence/jewelbug-crypto-fraud-espionage>
5. <https://www.darkreading.com/threat-intelligence/jewelbug-apt-state-espionage-cryptocurrency-theft>
6. <https://www.cyberhub.blog/article/30702-jewelbug-hacker-group-conducts-espionage-and-cryptocurrency-fraud-operations>
7. Threat Intelligence ฝ่ายบริหารจัดการข้อมูลภัยคุกคามทางไซเบอร์



แบบประเมินรายงานข่าวกรองไซเบอร์

<https://forms.gle/4QikxjAfRtsHogsn8>



จัดทำโดย

ฝ่ายบริหารจัดการข้อมูลภัยคุกคามทางไซเบอร์ สำนักประสานงาน  
ศูนย์ประสานการรักษาความมั่นคงปลอดภัยระบบคอมพิวเตอร์แห่งชาติ  
โทร: 02 114 3531 อีเมล: [cti\\_misp@ncsa.or.th](mailto:cti_misp@ncsa.or.th)